

Esercizio 6: Estrazione eseguibile da PCAP

Executive Summary

Il seguente report illustra le procedure di analisi di un file pcap tramite **Wireshark** e l'estrazione dell'eseguibile **W32.Nimda.Amm.exe** dalla cattura.

Obiettivi

- **Parte 1:** Analizzare Log e Catture di Traffico Pre-catturati
- **Parte 2:** Estrarre File Scaricati dal PCAP

Parte 1: Analizzare Log e Catture di Traffico Pre-catturati

La cattura nel file “nimda.download.pcap” rappresenta il traffico di rete per il download di un file eseguibile tramite protocollo HTTP:

The screenshot displays the Wireshark network protocol analyzer interface. The main pane shows a list of captured packets. Packet 4, at time 0.000565, is an HTTP GET request from 209.165.200.235 to 209.165.202.133 for the resource /W32.Nimda.Amm.exe. The packet details pane on the right shows the structure of the HTTP request, including the GET method, the URL, and the User-Agent header. The packet bytes pane at the bottom shows the raw data of the packet, including the Ethernet II header, Internet Protocol Version 4 header, and the Hypertext Transfer Protocol data.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	209.165.200.235	209.165.202.133	TCP	74	48598 → 6666 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=4051203246 TSecr=0 WS=51
2	0.000259	209.165.202.133	209.165.200.235	TCP	74	6666 → 48598 [ACK] Seq=0 Ack=1 Win=28960 Len=0 MSS=1460 SACK_PERM TSval=3023496465 TSecr=4051203246
3	0.000297	209.165.200.235	209.165.202.133	TCP	66	48598 → 6666 [ACK] Seq=1 Ack=1 Win=29696 Len=0 TSval=4051203246 TSecr=3023496465
4	0.000565	209.165.200.235	209.165.202.133	HTTP	230	GET /W32.Nimda.Amm.exe HTTP/1.1

Domanda 2

Ci sono alcune parole leggibili sparse tra i simboli. Perché sono lì?

Un file .exe è un file eseguibile che contiene istruzioni in codice macchina. Questi dati non sono pensati per essere letti come testo per il linguaggio umano pertanto Wireshark cerca di visualizzare ogni byte come un carattere: se un byte corrisponde a una lettera o un numero verrà visualizzato, se non corrisponde a nulla di leggibile, mostra un punto o simboli.

In sostanza, ciò che viene mostrato è il corpo del programma nel suo formato grezzo mentre attraversa la rete.

Domanda Sfida

Nonostante il nome W32.Nimda.Amm.exe, questo eseguibile non è il famoso worm. Per motivi di sicurezza, questo è un altro file eseguibile che è stato rinominato come W32.Nimda.Amm.exe. Usando i frammenti di parole visualizzati dalla finestra Follow TCP Stream di Wireshark, puoi dire quale eseguibile sia realmente?

In base all'analisi delle stringhe contenute nel flusso TCP, l'eseguibile reale è **cmd.exe**, ovvero il Prompt dei comandi di Windows rinominato come **W32.Nimda.Amm.exe**

```
....<?xml version="1.0" encoding="UTF-8" standalone="yes"?>
<!-- Copyright (c) Microsoft Corporation -->
<assembly xmlns="urn:schemas-microsoft-com:asm.v1" manifestVersion="1.0">
<assemblyIdentity
  version="5.1.0.0"
  processorArchitecture="amd64"
  name="Microsoft.Windows.FileSystem.CMD"
  type="win32"
/>
<description>Windows Command Processor</description>

<trustInfo xmlns="urn:schemas-microsoft-com:asm.v3">
  <security>
    <requestedPrivileges>
      <requestedExecutionLevel
        level="asInvoker"
        uiAccess="false"
      />
    </requestedPrivileges>
  </security>
</trustInfo>
```

Parte 2: Estrarre File Scaricati dal PCAP

Domanda 3

Perché W32.Nimda.Amm.exe è l'unico file nella cattura?

La cattura in questione non è l'intero traffico della rete ma un singolo flusso TCP relativo, in questo caso, alla conversazione tra un client e un server. Poiché la connessione è stata aperta esclusivamente per scaricare quel file via HTTP, non si vedranno altri file o navigazioni web nello stesso elenco.

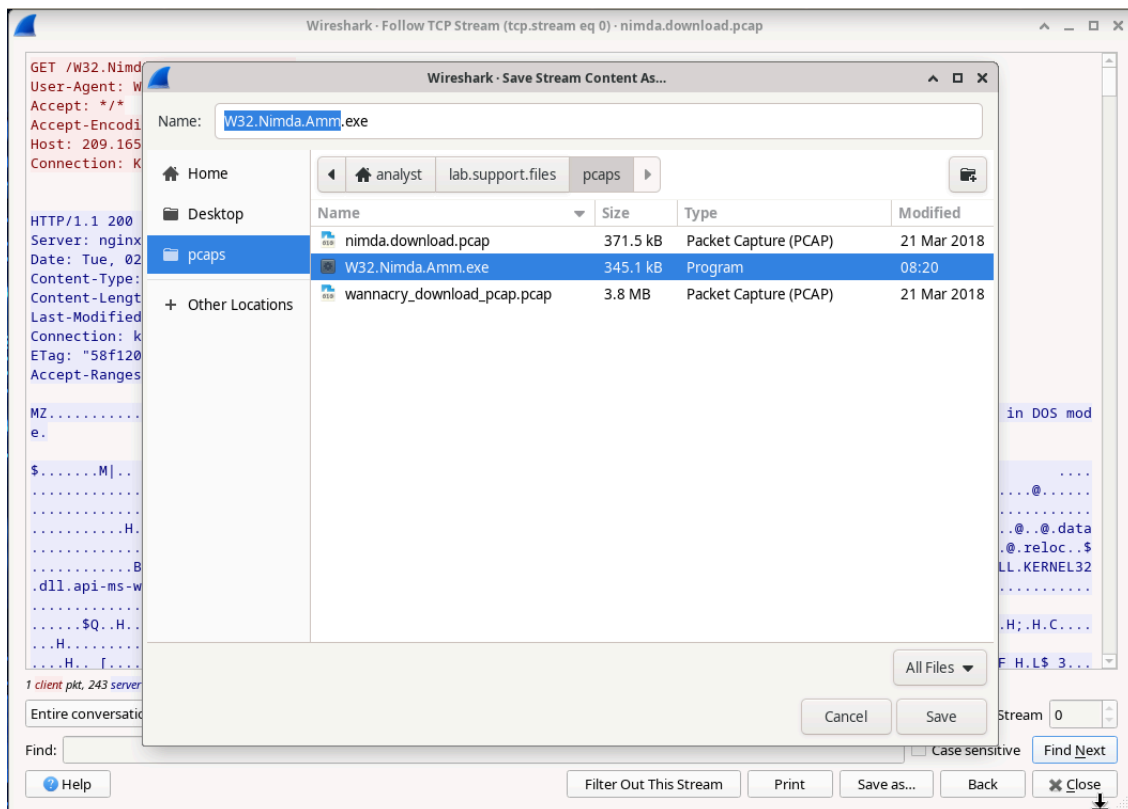
Inoltre, come indicato nel campo *User-Agent*, il download è stato effettuato con metodo Wget. A differenza di un browser che scarica contemporaneamente icone, script e immagini per visualizzare una pagina, Wget, essendo uno strumento da riga di comando, scarica solo il file specifico indicato nell'URL.

```
▶ Frame 4: 230 bytes on wire (1840 bits), 230 bytes captured (1840 bits) on interface eth0
▶ Ethernet II, Src: ea:05:2c:e1:90:3d (ea:05:2c:e1:90:3d), Dst: 16:4c:37:9e:eb:50 (16:4c:37:9e:eb:50)
▶ Internet Protocol Version 4, Src: 209.165.200.235, Dst: 209.165.202.133
▶ Transmission Control Protocol, Src Port: 48598, Dst Port: 6666, Seq: 1, Ack: 1, Len: 164
▼ Hypertext Transfer Protocol
  ▶ GET /W32.Nimda.Amm.exe HTTP/1.1\r\n
    User-Agent: Wget/1.19.1 (linux-gnu)\r\n
    Accept: */*\r\n
    Accept-Encoding: identity\r\n
    Host: 209.165.202.133:6666\r\n
    Connection: Keep-Alive\r\n
    \r\n
    [Response in frame: 309]
    [Full request URI: http://209.165.202.133:6666/W32.Nimda.Amm.exe]
```

Domanda 4

Il file è stato salvato?

Sì, il file è stato salvato.



Domanda 5

Nel processo di analisi del malware, quale sarebbe un probabile passo successivo per un analista di sicurezza?

Il passo successivo per un analista di sicurezza può essere:

1. Analisi Statica di Base

- **Fingerprinting:** calcolo degli hash per il confronto con database di threat intelligence;
- **Analisi delle stringhe:** ricerca di indirizzi IP, domini, ecc.;
- **Controllo dell'header:** identificazione di packer o offuscatori, analisi delle librerie importate).

2. Analisi Dinamica (Sandboxing)

Si esegue il malware in un ambiente controllato e isolato per osservarne il comportamento in tempo reale:

- **Monitoraggio dei processi:** osservare se il malware crea nuovi processi o inietta codice in quelli legittimi;
- **Modifiche al File System e Registro:** tracciare la persistenza;
- **Analisi del traffico di rete:** identificare tentativi di connessione verso server.